



File No.: EXP202414366

RESOLUTION FOR TERMINATION OF THE PROCEDURE DUE TO ADMISSION OF RESPONSIBILITY AND VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On April 15, 2025, the Presidency of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against A.A.A. (hereinafter, A.A.A.), through the agreement transcribed below:

<<

File No.: EXP202414366

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: The Spanish Agency for Data Protection (AEPD) has become aware of certain facts that could constitute possible infringements attributable to A.A.A. with NIF: ***NIF.1 (hereinafter, A.A.A., the pharmacy, A.A.A. or the accused party), as the holder of the pharmacy office ***NIF.2, following a complaint filed by the Direcció General D'Ordenació i Regulació Sanitària of the Autonomous Community of Catalonia, after conducting inspections of pharmacy offices in the exercise of its competencies.

The complaint was received by the AEPD on September 7, 2023, forwarded by the Autoritat Catalana de Protecció de Dades in compliance with Article 14 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector.

In it, the Direcció General D'Ordenació i Regulació Sanitària alerts about possible violations of data protection regulations regarding the processing of personal data of residents in geriatric centers by certain pharmacy offices, including, among others: alleged unauthorized access and transfers of personal health data or the exchange of personal data through insecure electronic means.

SECOND: As a consequence of the known facts, on October 19, 2023, the Director of the Spanish Agency for Data Protection urged the General Subdirectorate for Data Inspection (SGID) to initiate the preliminary investigation actions referred to in Article 67 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD).

All this in order to collect the necessary elements of judgment to thoroughly understand the described facts and the treatments carried out to determine, if applicable, the consequences that may arise from them for the rights and freedoms of individuals.

THIRD: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VIII of the LOPDGDD.

As a result of the actions taken, the following points have been noted:

1. Regarding the information provided by the Pharmacy Inspection Service.

In its response letter, dated January 22, 2024, the Pharmacy Inspection Service provides the following information regarding the accused pharmacy:

"On February 14, 2024, an inspection of the pharmacy ***NIF.2, located at ***ADDRESS.1, was conducted, whose owners are B.B.B. and C.C.C..

• Ms. C.C.C. stated that they began dispensing diapers to residences with the company ***COMPANY.1, located at ***ADDRESS.2 (invoices were detected between November 2017 and February 2019). The first dispensations were for the users of the Residence ***RESIDENCE.1, which a pharmacy on ***ADDRESS.3 supplied with medications. The contact person for that pharmacy was Mr. D.D.D..

- In February 2019, they were visited by Mr. E.E.E. (**COMPANY.2) who informed them that if they wanted to continue with the dispensing of diapers, the residence would change suppliers and the supply would be provided by **COMPANY.2.
- On October 28, 2022, they received an email informing them that from that moment on, the contact pharmacy would be pharmacy **F.F.F., in Barcelona, and the contact email was: **EMAIL.1.
- She also mentions that between January and May 2023, there were many discrepancies between the sealing coupons provided by **COMPANY.2 and the list of diapers to be dispensed sent by email by pharmacy **F.F.F., so they had to claim several times since they did not want or could make certain substitutions and that, starting from May 26, 2023, pharmacy **F.F.F. communicated a change of residence and began supplying to Residence **RESIDENCE.2, thus minimizing the inconsistencies that had been detected in recent months.

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sede.aepd.gob.es
 3/50

- They do not request the diapers, but rather **COMPANY.2 delivers them directly to the residences, and subsequently, the delivery person brings them the seal coupons and the delivery notes with the diapers ordered from the Pharmacy **F.F.F. The pharmacy **F.F.F. sends them an Excel file with the names and surnames of the patients and the diapers to be dispensed via an unencrypted email. The pharmacy had provided them access (username and password) to the software program **PROGRAM.1 with which they obtain the name, CIP, and active prescription number of the residents in order to dispense the diapers (with the change of residence, they also changed the password). Before the 25th of each month, they send an email with a file to the pharmacy **F.F.F., which contains the names of the residents, type of diaper, dispensing date, and specific monetary contribution of each resident. Also monthly, they send an email to Mr. E.E.E. of **COMPANY.2: **EMAIL.2 with the general invoice for the dispensing of diapers and, along with the last delivery of the month of seal coupons, the carrier from **COMPANY.2 delivers them an envelope with cash containing the total amount of the contributions. They do not have any authorization from the residents to access their electronic prescription and have no contact with them.
 - On the day before the inspection visit conducted, on February 13, 2023, [typographical error in the record: the correct date is 13/02/2024] they had received a call from Mr. D.D.D. and subsequently an email informing them of a new change of contact pharmacy. It was the pharmacy **NIF.3, whose owner is F.F.F., located at **ADDRESS.3, and contact email: **EMAIL.3.
- On the same day, 13/02/2024, the Pharmacy **ADDRESS.3 sent them an email with the names of the residents and the diapers to be dispensed, which they state did not match the usual residents of the **RESIDENCE.2 and that with the credentials of **PROGRAM.1 they have, they cannot access any prescription.

Furthermore, the Pharmacy Inspection sends the record of the inspection conducted on 14/02/2024, the content of which is reproduced below:

1.1.

RECORD

(...)

of inspection to pharmacy

A.A.A.

Record of Pharmacy Inspection conducted to gather information, whose main data are:

(...)

(...)

(...)

(...)

(...)

(...).

Unofficial translation:

“(...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

4/50

(...):

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

-

(...):

(...)

-

(...):

a) (...)

b) (...)

c) (...)

d) (...)

- (...)

- (...)

- (...)

- (...)

- (...).”

1.1.

Annexes of the Inspection Record.

This Record includes the following evidence:

- Email dated 25/10/2022 from ***EMAIL.4 to ***EMAIL.5 attaching a list of diaper users.

- Email dated 31/10/2022 from ***EMAIL.5 to ***EMAIL.4 attaching a list of “contributions.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

5/50

- Email dated 26/05/2023 from ***EMAIL.1 to ***EMAIL.5 communicating the change of residence to the ***RESIDENCE.2, to which to supply the diapers. Response on the same day 26/05/2023, from the pharmacy A.A.A. to pharmacy F.F.F., accepting the change.

- Email dated 31/05/2023 from ***EMAIL.1 to ***EMAIL.5 attaching a list of diapers for the ***RESIDENCE.2.

- Email dated 1/06/2023 from ***EMAIL.5 to ***EMAIL.1 attaching “contributions” from G.G.G.
- Email dated 24/11/2023 from ***EMAIL.5 to ***EMAIL.2 in which 6 files of contributions corresponding to the months of October and November are attached for a total amount of €363.56.
- Email dated 25/01/2024 from ***EMAIL.5 to ***EMAIL.1 attaching a list of “(…).”
- Email dated 13/02/2024 from ***EMAIL.3 to the pharmacy ***ADDRESS.3 where it communicates the change from Pharmacy F.F.F. to it.
- Email dated 13/02/2024 from pharmacy ***ADDRESS.3 where it attaches, unencrypted, an Excel sheet with the full names of users and diapers to be dispensed. (they do not communicate any change of access data to ***PROGRAM.1).
- Photographs of invoices from ***COMPANY.1 dated 31/01/2019, from ***COMPANY.3 dated 28/02/2019, from ***COMPANY.2 dated 31/01/2024, and the internal instructions of Pharmacy A.A.A. for dispensing and billing the diapers to residences.”

2.

Information provided in the responses to the information requests.

On 6/11/2024, a request for information is made to the reported party requesting, among other points, the list of residences to which it provides or has provided service, description of the treatments performed and its legal basis, a copy of the Record of Treatment Activities (RAT), Risk Analysis (RA), and Impact Assessment (hereinafter, EIPD) and information about the exchange of personal data with third parties.

The reported party responds to this request for information with a registration date of 20/11/2024, providing the following documentation:

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeaepd.gob.es
 6/50

-

Document of personal data transfer between Pharmacy F.F.F. and Pharmacy A.A.A. dated 2/01/2023 and unsigned by either party.

-

Document of personal data transfer between Pharmacy ***ADDRESS.3 and Pharmacy A.A.A. dated 13/02/2023 and unsigned by either party.

-

Confidentiality agreements signed by four employees of the pharmacy office, all dated 2/01/2023.

-

Screenshot of access to the application ***PROGRAM.1 for residents of the residences ***RESIDENCE.1 and ***RESIDENCE.2, showing two email addresses for access (...) and the passwords (...).

-

Activity Log. Document dated 2/01/2023 and without a signature.

-

Impact Assessment Report. Document dated 2/01/2023 and without a signature.

2.1. Residences to which services are provided or have been provided.

The accused party states in its response to the request, "It is important to clarify that our actions regarding the personal data of the residents of ***RESIDENCE.1 and ***RESIDENCE.2 have been limited and specific. The pharmacy has provided services for the supply of urinary incontinence pads to the residences, but has not acted as the data controller or as the data processor of the personal data of the residents. In this regard, the pharmacy has received data from other pharmacies that, as data processors, have provided the necessary information for the correct provision of the requested products. Therefore, the pharmacy has not had direct access to the personal data of the residents, but has acted based on the information that has been transferred to it by third parties (art.26 GDPR). When asked about the number of residents in each residence to whom urinary incontinence pads (diapers) are provided, the legal basis for processing the personal data of the residents for this

dispensing, the copy of the contracts signed with each of the residences, and the procedures followed to fulfill the duty of informing the residents about the processing of their personal data, the accused party does not provide information on these matters.

2.2.

Responsibility in Data Processing.

The accused party states in its response to the request,

“3. (...) In this case, the pharmacy has not determined the purposes or means of processing the data of the residents of the nursing home, but has acted based on the information that was transferred to it by other pharmacies for the provision of diapers, which exempts it from being considered the data controller or processor. Furthermore, the regulations establish that the transfer of data between pharmacies must be duly regulated and justified, and that the data processor must act under the instructions of the controller (GDPR art.28.3). In this sense, the pharmacy in question has not had direct access to the residents' data, but has received information from other pharmacies, which implies that it has not carried out autonomous processing of such data.”

“4. (...) The pharmacy acted within the limits of its function, without assuming responsibilities that did not correspond to it in the processing of data. In this case, the pharmacies that transferred the data are the ones that must assume responsibility, as they were the ones who decided to share the information.”

The accused party provides documents of personal data transfer between Pharmacy ***ADDRESS.3 and Pharmacy A.A.A. (13/02/2023) and between Pharmacy F.F.F. and Pharmacy A.A.A. (02/01/2023). It is noted that both documents are identical (except for the name of the pharmacy making the transfer) and that certain fields are not completed.

It is noteworthy that the date of the document of data transfer between Pharmacy ***ADDRESS.3 and Pharmacy A.A.A. is 13/02/2023 and that the informative email communicating the change to Pharmacy ***ADDRESS.3 is dated 13/02/2024, that is, one year later.

From the documents of data transfer, the following information is extracted:

Pharmacy ***ADDRESS.3 (Pharmacy A) // Pharmacy ***F.F.F. (Pharmacy A) and Pharmacy A.A.A. (Pharmacy B):

“They agree to the transfer of personal data of the residents of the geriatric center [Name of the Geriatric Center] for the dispensing of diapers.

Clauses:

1.

Purpose of the Transfer: The purpose of this transfer is to allow Pharmacy B to access the personal data of the residents of the geriatric center [Name of the Geriatric Center] for the dispensing of diapers and related products, ensuring at all times the confidentiality and security of the data processed.

2.

Data to be Transferred: The personal data to be transferred includes:

- Name and surname
- Date of birth
- Resident identification number
- Information about the need for diapers

8/50

3.

Legitimizing Basis: The data transfer is based on compliance with a legal obligation and the vital interest of the residents, in accordance with the provisions of the GDPR, particularly Article 6.1.c and 9.2.c.

4.

Consent: Pharmacy A commits to obtaining the explicit consent of the residents or their legal representatives for the transfer of their personal data to Pharmacy B, ensuring that such consent is freely given, specific, informed, and unambiguous.

5.

Purpose of Processing: The personal data transferred will be used exclusively for the dispensing of diapers and may not be used for any other purposes without the prior consent of the data subject.

6.

Rights of the Data Subjects: Both parties commit to ensuring the exercise of the rights of access, rectification, erasure, restriction of processing, data portability, and objection of the data subjects, in accordance with the provisions of the GDPR.

7.

Security Measures: Pharmacy B commits to implementing appropriate technical and organizational measures to ensure the security of the transferred personal data, preventing unauthorized or unlawful processing and accidental loss, destruction, or damage.

8.

Duration of the Transfer: The data transfer will last for [specify duration], from the date of signing this document, unless otherwise agreed by both parties.

9.

Confidentiality: Both parties commit to maintaining the confidentiality of the transferred personal data and not disclosing it to third parties without the prior consent of the data subject, except in cases where the law requires it.

2.3.

Compliance with Data Protection Regulations.

The reported party states in its response to the request:

“The A.A.A. is committed to complying with all obligations established in the General Data Protection Regulation (GDPR) and the Organic Law on Data Protection and Guarantee of Digital Rights (LOPDGDD) with the pharmacy staff. In this regard, appropriate measures have been implemented to ensure the security and confidentiality of the data being handled. (DOCUMENT 3).”

The reported party provides the confidentiality agreements signed by four employees of the pharmacy office, all dated January 2, 2023:

Employees signing the agreement:

- B.B.B.
- H.H.H.
- I.I.I.
- J.J.J.

The agreements reflect the following information:

1. Data transfer and protection of employee data.

The purposes of processing their data will be as follows:

- Human Resources: to develop, maintain, comply with, and control their activity, and to fulfill the obligations and functions of the Human Resources department related to training activities, attendance control at work, payroll processing, duties regarding occupational risk prevention, as well as the management of communication/whistleblowing channels implemented by the entity in accordance with the requirements set forth in the applicable compliance regulations.

[...]

2. Confidentiality of the data.

In light of our highest commitment to comply with current legislation, we inform you of the following aspects:

- Resources of information systems: It is strictly prohibited to use such resources to which access is granted for private use or for any purpose other than the performance of your functions. Under no circumstances may information be disclosed to anyone outside the company without the proper authorization.
- The computer systems that provide access to processes containing personal data will always have this access restricted by a user code and password.
- Email: When data from the Processing is sent via email, transmissions will always and only be made from an email address controlled by the Data Controller and owned by the organization, keeping a record of these transmissions. The organization reserves the right to review the corporate email message log of the user without prior notice, to prevent any misuse. When the data from the Processing must be sent outside the physically protected premises where the data is located, whether by means of a physical data recording medium or via email, they must be encrypted - this will be

mandatory in the case of sensitive data - so that they can only be read and interpreted by their intended recipient(s). Any user who becomes aware of an incident is responsible for reporting it to the Security Officer.

- The user code and password are personal and non-transferable: therefore, the records made regarding operations carried out under a code and password will be attributed, unless proven otherwise, to the holder of the same and will remain under their responsibility.

- Each user is responsible for the confidentiality of their password. If there is any issue with it, they must register it as an incident and notify the Security Officer immediately.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede.aepd.gob.es

10/50

- Exit of supports: Any exit of support and/or personal computer outside the company must be expressly authorized. In the case that the user has digital devices supplied by the organization (mobile phones, tablets, laptops), these will be used exclusively for organizational matters, and private use of the same is not permitted. These devices will always be available to the organization for supervision.

- Security incidents: Anyone who becomes aware of an incident is directly and personally responsible for reporting it. Any attempt by the user to gain unauthorized access to protected data, attempts to disable the implemented security controls and measures, and knowledge of and failure to report any incident or exercise of rights of access, rectification, cancellation, limitation, transparency, erasure, and portability will be considered a violation against the security of the Processing by that user.

- Professional secrecy: All personnel of the Data Controller are obliged not only to the utmost professional secrecy but also to neutrality and maximum discretion regarding the personnel of the clients and suppliers of the Data Controller. All information provided or entrusted to our personnel, as well as all conversations in which they participate, will therefore be considered strictly confidential. Personnel providing services at the clients' premises, in addition to complying with what is indicated in this document, must enforce the obligations and commitments provided by the client regarding data protection, duty of secrecy, and information security.

2.2.

Impact Assessment (EIPD)

The accused party provides the Impact Assessment document related to data protection concerning a single processing:

“Processing to be evaluated: prescription and psychotropic book.”

3.

Third parties

Requested information about third parties related to the pharmacy that carry out processing with the data of the residents, as well as the description of such processing, the legal basis that legitimizes such processing, and a copy of the contracts for data processing/sub-processing, the investigated party does not provide information on this matter.

4.

Exchange of personal data of the residents

Consulted about the procedure for exchanging personal data between the pharmacy office, the residences, and other third parties, the accused party responds:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede.aepd.gob.es

11/50

“The pharmacy also ensured that any personal data received was duly protected and that appropriate security measures were taken to prevent unauthorized access (USER AND PASSWORD for access to

the equipment), in accordance with the provisions of the GDPR art.32 on the security of processing, and that the files received in Excel required a password to access them. (WINRAR, option CREATE PASSWORD).”

5.

Use of software, Excel sheets, or similar for collecting data from residents.

Consulted about the use of software, Excel sheets, or similar for collecting data from residents, the accused party does not provide information on this topic.

6.

Program ***PROGRAM.1

Requested confirmation of the use of the ***PROGRAM.1 program to access the data of the residents and information about the type of data obtained from said program, the accused party indicates:

“7. Regarding the ***PROGRAM.1 program, DOCUMENT 4 is attached, with user and password, in addition to screenshots of its access.

The type of data of the residents obtained from the ***PROGRAM.1 program for the dispensing of urinary incontinence pads are:

- Name and surname.
- National Code.
- Type and size of the pads.”

Furthermore, the cited document “Access to ***PROGRAM.1” consists of the users and passwords for access to ***PROGRAM.1 for residents of the ***RESIDENCE.1 and ***RESIDENCE.2 and a screenshot of access to the ***PROGRAM.1 program where it is verified that a user and password are requested.

The accused party concludes their writing by requesting that it be considered that the pharmacy has not been responsible for or in charge of the processing of personal data of the residents of the residences.

FOURTH: The pharmacy office A.A.A. is owned by A.A.A., with NIF ***NIF.1. The community of goods is made up of B.B.B., with NIF ***NIF.4 and C.C.C., with NIF ***NIF.5.

LEGAL GROUNDS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

12/50

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

II

Procedure

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

In accordance with Article 64 of the LOPDGDD, and taking into account the characteristics of the alleged infringements committed, a sanctioning procedure is initiated.

The procedure shall have a maximum duration of twelve months from the date of the initiation agreement. Upon the expiration of this period, it will lapse, and consequently, the file will be archived, in accordance with the provisions of Article 64 of the LOPDGDD.

If no allegations are made against this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

III

Preliminary Issues

1. Applicable Sectoral Regulations

1.1 Pharmacies

Pharmacies are, according to Article 86.6 of Royal Legislative Decree 1/2015, of July 24, which approves the consolidated text of the Law on Guarantees and Rational Use of Medicines and Health Products, private healthcare establishments of public interest.

Their regulation is found, among other applicable norms, in Law 14/1986, of April 25, General Health Law; Law 16/1997, of April 25, on the Regulation of Pharmacy Office Services; Royal Legislative Decree 1/2015, of July 24, which approves the consolidated text of the Law on Guarantees and Rational Use of Medicines and Health Products; as well as in the applicable regional legislation such as, in the case of Catalonia, Law 31/1991, of December 13, on Pharmaceutical Regulation of Catalonia.

Both Law 14/1986, of April 25, and Law 16/1997, of April 25, state: “the pharmacist owner of the same, assisted, where appropriate, by assistants or auxiliaries, must provide the following basic services to the population:

1. The acquisition, custody, conservation, and dispensing of medicines and health products.
2. The monitoring, control, and custody of the dispensed medical prescriptions (...).”

For its part, Article 3 of Royal Legislative Decree 1/2015, of July 24, is more emphatic in stating that the custody, conservation, and dispensing of medicines for human use corresponds exclusively to:

“a) Pharmacies open to the public, legally authorized.

b) The pharmacy services of hospitals, health centers, and primary care structures of the National Health System for their application within such institutions or for medicines that require particular monitoring, supervision, and control by the multidisciplinary health care team, in accordance with the qualification granted by the Spanish Agency for Medicines and Health Products for such medicines (...).”

Pharmacies are obliged, according to Article 86.3 of Royal Legislative Decree 1/2015, of July 24, to “dispense medicines requested by both individuals and the National Health System under the established regulatory conditions.” However, the principle of free choice of pharmacy must be respected. Thus, this regulation establishes as a serious infringement in its Article 111 b):

“26th. Restricting the user's freedom in choosing the pharmacy through any act or omission.”

It is also classified as a serious infringement in the same article:

“22nd. Defrauding the National Health System or its beneficiaries in relation to the billing and collection of official prescriptions.”

It is also emphasized that, according to the aforementioned Royal Legislative Decree 1/2015, of July 24, it constitutes a very serious infringement according to Article 111 c):

“23rd. Conducting, by pharmacies, activities of distribution of medicines to other pharmacies, authorized distribution entities, or other entities, centers, or individuals without authorization to do so.”

14/50

the activity of distribution or the shipment of medications outside the national territory.”

For its part, Law 16/1997, of April 25, enshrines the figure of the pharmacist as an essential and indispensable element for the functioning of a pharmacy by determining in its Article 5:

“1. The presence and professional action of a pharmacist is an inexcusable condition and requirement for the public dispensing of medications. The collaboration of assistants or auxiliaries does not excuse the action of the pharmacist in the pharmacy while it remains open to the public, nor does it exclude their professional responsibility.

2. The Autonomous Communities may regulate the minimum number of assistant pharmacists, in addition to the owner, who must provide services in pharmacies to ensure adequate professional assistance to users. This regulation must take into account, among other factors, the volume and type

of activity of the pharmacies and the schedule of services.

3. Without prejudice to the action of the assistant, the owner pharmacist shall be responsible for ensuring service to users.”

Likewise, Article 103 of Law 14/1986, of April 25, General Health Law states:

“1. The custody, conservation, and dispensing of medications shall correspond to:

a) Legally authorized pharmacies.

b) The pharmacy services of hospitals, Health Centers, and Primary Care structures of the National Health System for their application within such institutions or for those requiring particular monitoring, supervision, and control by the multidisciplinary health care team.

2. Pharmacies open to the public are considered health establishments for the purposes provided in Title IV of this Law.

3. Pharmacies shall be subject to health planning in the terms established by the special legislation on medications and pharmacies.

4. Only pharmacists may be owners and holders of pharmacies open to the public.”

Consequently, the owner of the pharmacy is the one who is responsible for the actions carried out by the pharmacy and to whom responsibilities may be demanded.

1.2 Dispensing of Medications

In addition to the aforementioned regulations, the Royal Decree 1718/2010, of December 17, on medical prescriptions and dispensing orders is of interest regarding pharmaceutical dispensing, whose Chapter IV is dedicated to “the official electronic medical prescription of the SNS,” contemplating the general criteria for its development, as well as coordination in the SNS. In its Article 9, it states:

“1. Dispensing shall be carried out by pharmacies connected to the electronic medical prescription system, through the standardized procedure established by the competent health authorities, which will determine its specific conditions, requiring the electronic certificate of the owner of the pharmacy, or, where applicable, of the managing, assistant, or substitute pharmacist, issued by the competent entity.

2. After the unequivocal identification of the patient, and where applicable, of the person to whom they delegate, the pharmacist may only access, from the equipment installed in the pharmacy, with the requirements and conditions established in the following section, the necessary data for a correct informed dispensing and follow-up of the treatment and shall dispense exclusively, from among the pending prescriptions, those requested by the patient.

3. Access to the electronic system by pharmacists will only be allowed through the patient’s health card duly recognized by the electronic prescription system, which must be returned immediately to its holder and may not be retained in the pharmacy. The pharmacist’s access will always be recorded in the aforementioned system.

4. At the time of dispensing, the electronic prescription systems must incorporate and send to the corresponding health administrations, the identification data of the dispensed product, coded according to the official nomenclature of pharmaceutical products of the National Health System, the number of dispensed packages and their unit identification when possible, identification of the dispensing pharmacy, using the NIF/CIF of its holder, as well as the identification number of the pharmacy granted by the competent health administration, and the date of dispensing, in the format that the national exchange node has established for this purpose. This information will be the only one retained for billing purposes in the collegiate pharmaceutical organization, as long as it acts as responsible for it, and will be available to the competent health administrations in accordance with their applicable regulations.”

Likewise, in its Article 11 it determines:

“The electronic medical prescription system will guarantee the security in access and transmission of information, as well as the protection of the confidentiality of data, in accordance with the provisions of Organic Law 15/1999, of December 13, on the protection of personal data. High-level security measures, as provided in the aforementioned personal data protection regulations, will be implemented. To guarantee such security levels, this information will only be accessible from the pharmacy for dispensing purposes, will reside permanently in the electronic prescription systems managed by the health administrations, and may not be...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeapd.gob.es
16/50

to be stored in repositories or servers not belonging to them, established to carry out billing, once it has occurred.”

At the regional level, in Catalonia, the Royal Decree 159/2007, of July 24, stands out, regarding the electronic prescription and the telematic processing of pharmaceutical provision under the Catalan Health Service.

Lastly, it is worth noting Order SLT/72/2008, of February 12, which develops Royal Decree 159/2007, of July 24, regulating electronic prescriptions and the telematic processing of pharmaceutical provision under the Catalan Health Service. Article 7 states:

“In order to access the dispensing of electronic prescriptions, the patient must be identified as the holder of the right to pharmaceutical provision at the pharmacy by presenting the individual health card, and must provide the pharmacist with the active medication sheet that includes the treatment for which the dispensing of the product included in the pharmaceutical provision is requested.”

2. On the presumption of veracity of the Pharmacy Inspection reports

Article 108 of Royal Legislative Decree 1/2015, of July 24, which approves the consolidated text of the Law on guarantees and rational use of medications and health products, states that it is the responsibility of health administrations within their competencies to carry out the necessary inspections to ensure compliance with the provisions of this law.

This article practically reproduces the provisions of Article 30 of Law 14/1986, of April 25, General Health Law, which states that “all health centers and establishments, as well as promotional and advertising activities, shall be subject to inspection and control by the competent Health Administrations.”

Both regulations provide, in their Articles 108.3 and 31 respectively, for such purposes, a series of powers for personnel serving the Public Administrations in the exercise of inspection authority, including the possibility of entering freely and without notification into the centers subject to them, such as pharmacies; as well as proceeding with the necessary tests, investigations, or examinations to verify compliance with regulations; taking samples, in order to verify compliance, as well as carrying out any actions necessary to fulfill the inspection functions they perform.

At the regional level, Law 26/2010, of August 3, on the legal regime and procedure of public administrations in Catalonia, enshrines in its Article 89.2 the consideration of authority of the personnel of its Administration responsible for public inspection and control functions.

In this regard, it is worth noting that Article 77.5 of the LPACAP establishes the presumption of veracity of documents signed by public employees that

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeapd.gob.es
17/50

they shall be considered as authority, unless proven otherwise. Specifically, it states:

“the documents formalized by the officials recognized as authority and in which, observing the corresponding legal requirements, the facts established by them are recorded, shall serve as proof of these facts unless proven otherwise.”

In the same sense, the aforementioned Law 26/2010, of August 3, of Catalunya in its article 90.1 determines that the facts established by the personnel of the Administration responsible for public inspection and control functions, and which are formalized in a public document observing the legally established requirements, have evidentiary value, without prejudice to the evidence that may be provided by the interested parties in defense of their rights and interests.

Consequently, the minutes must be signed unavoidably by the inspector, without prejudice to the fact that the lack of signature by the inspected party does not invalidate the minutes or their evidentiary

value.

3. Responsibility for processing in the field of personal data protection

Article 4.1) of the GDPR defines “personal data” as: “any information relating to an identified or identifiable natural person (‘the data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.”

Article 4.2) of the GDPR defines “processing” as: “any operation or set of operations performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment, combination, restriction, erasure or destruction.”

Article 4.7) of the GDPR defines the “data controller” or “controller” as: “the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be provided for by the law of the Union or of the Member States.” In turn, Article 4.8) of the GDPR defines the “processor” or “processor” as the natural or legal person, public authority, agency or other body that processes personal data on behalf of the controller.

For its part, the Guidelines 07/2020 of the European Data Protection Board on the concepts of “data controller” and “data processor” (hereinafter, Guidelines 07/2020) emphasize that the concepts of data controller and data processor are functional concepts, and it is necessary to establish them based on their specific activities in the analyzed case and not based on the formal designation that may appear in the contract:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sede.aepd.gob.es
18/50

“12. The concepts of ‘data controller’ and ‘data processor’ are functional concepts: their objective is to assign responsibilities based on the actual role of each party. This implies that the legal status of ‘data controller’ or ‘data processor’ of the participants must be established primarily based on their specific activities in a given situation and not based on the formal designation of a participant as ‘data controller’ or ‘data processor’ (e.g., in a contract). This implies that the assignment of the role of controller or processor should normally derive from an analysis of the facts or circumstances of the case and, consequently, is not negotiable.” (underlined by the AEPD).

In short, the identification of the controller must be carried out according to material criteria in accordance with the real conditions and circumstances of each processing operation; it cannot be understood as a mere formal acknowledgment of what is stated, for example, in a contract signed between parties. Thus, there will be occasions when the participants in a chain of processing operations have been respectively identified as controller and processor, and yet, based on who determines the purpose of the processing and the essential means thereof, the role of controller corresponds to someone who was not formally identified as such.

In addition to what has been stated so far, it should be noted that the aforementioned Guidelines of the EDPB highlight:

“20. (...) The data controller is the one who decides on certain essential aspects of the data processing. The responsibility for processing can be established in the regulations or inferred from an analysis of the facts or circumstances of the case. It is necessary to focus on the specific processing activities in question and understand who determines them. To this end, the following questions must first be examined: ‘Why is the processing taking place?’ and ‘Who has decided that the processing should be carried out for a specific purpose?’.” (underlined by the AEPD).

Furthermore, the aforementioned EDPB Guidelines 07/2020 advocate for a broad interpretation of the

concept of data controller in order to promote effective and comprehensive protection of data subjects. In this regard, they provide:

“14. Since the ultimate objective of assigning the role of data controller is to ensure proactive responsibility and effective and comprehensive protection of personal data, the concept of ‘controller’ should be interpreted broadly enough to promote, as far as possible, effective and comprehensive protection of data subjects, in order to ensure the full effectiveness of Union law on data protection, avoid gaps, and prevent possible circumventions of the regulations, without this implying a reduction of the powers of the data processor.” (underlined by the AEPD).

On the other hand, as stated in Article 4.7 of the GDPR, it is possible that sometimes a regulation defines the controller, either implicitly or explicitly.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@epd.gob.es

19/50

explicit. Thus, it may occur that a regulation establishes obligations that involve the processing of personal data and assigns it to a specific entity, which will have the status of data controller from the perspective of data protection.

The respondent states in its written response to the request that "it has not acted as a data controller or as a data processor for the personal data of the residents, but rather has 'received data from other pharmacies that, as data processors, have provided the necessary information for the correct provision of the requested products. Therefore, the pharmacy has not had direct access to the personal data of the residents, but has acted based on the information that has been provided to it by third parties.'

Furthermore, it points out that 'the pharmacy has not determined the purposes or means of processing the data of the residents of the nursing home, but has acted based on the information that was provided to it by other pharmacies for the provision of diapers, which exempts it from being considered a data controller or data processor.'"

In the present case, according to the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, since the dispensing of diapers carried out by the respondent involves a set of operations performed on personal data such as accessing the personal data contained in the National Health System (SNS), or in the ***PROGRAM.1, its consultation and verification, as well as its structuring and organization.

In this regard, it cannot be overlooked that the aforementioned sectoral regulation exclusively assigns to pharmacies the dispensing of medications or health products that require a prescription, such as diapers, without the possibility of subcontracting or delegating between pharmacies. This is derived from the aforementioned Article 111 c) 23rd of Royal Legislative Decree 1/2015, of July 24, which approves the consolidated text of the Law on guarantees and rational use of medications and health products, which establishes the following as a very serious infringement:

"23rd. The performance, by pharmacies, of distribution activities of medications to other pharmacies, authorized distribution entities, or other entities, centers, or individuals without authorization for the distribution activity or the sending of medications outside the national territory."

In light of the above, the respondent carries out this activity in its capacity as data controller, given that it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

4.

Health data as special category data.

Article 9 of the GDPR, which regulates the processing of special categories of personal data, establishes the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@epd.gob.es

20/50

"1. The processing of personal data revealing ethnic or racial origin, political opinions, religious or philosophical beliefs, or trade union affiliation is prohibited, as well as the processing of genetic data, biometric data aimed at uniquely identifying a natural person, health-related data, or data related to the sexual life or sexual orientation of a natural person.

2. The provisions of paragraph 1 shall not apply when one of the following circumstances occurs:

- a) the data subject has given explicit consent to the processing of such personal data for one or more specified purposes, except when Union law or the law of the Member States provides that the prohibition mentioned in paragraph 1 cannot be lifted by the data subject;
- b) the processing is necessary for compliance with obligations and the exercise of specific rights of the data controller or the data subject in the field of labor law and social security and protection, to the extent that it is authorized by Union law or the law of the Member States or a collective agreement under the law of the Member States that establishes adequate safeguards for the respect of fundamental rights and the interests of the data subject;
- c) the processing is necessary to protect vital interests of the data subject or another natural person, in the event that the data subject is not physically or legally capable of giving consent;
- d) the processing is carried out, within the scope of its legitimate activities and with appropriate safeguards, by a foundation, association, or any other non-profit body whose purpose is political, philosophical, religious, or trade union, provided that the processing relates exclusively to current or former members of such bodies or to persons who have regular contact with them in relation to their purposes and provided that the personal data are not communicated outside of them without the consent of the data subjects;
- e) the processing concerns personal data which the data subject has made manifestly public;
- f) the processing is necessary for the formulation, exercise, or defense of claims or when courts act in the exercise of their judicial functions;
- g) the processing is necessary for reasons of essential public interest, based on Union law or the law of the Member States, which must be proportional to the objective pursued, respect the right to data protection in essence, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject;
- h) the processing is necessary for preventive or occupational medicine, the assessment of the worker's capacity to work, medical diagnosis, the provision of health or social care assistance or treatment, or the management of health and social care systems and services, based on Union law or the law of the Member States."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@pd.gob.es

21/50

members or under a contract with a healthcare professional and without prejudice to the conditions and guarantees set forth in paragraph 3;

- i) the processing is necessary for reasons of public interest in the field of public health, such as the protection against serious cross-border health threats, or to ensure high standards of quality and safety of healthcare and of medicines or medical products, based on Union law or the laws of the Member States that establish adequate and specific measures to protect the rights and freedoms of the data subject, in particular professional secrecy;
- j) the processing is necessary for archiving purposes in the public interest, for scientific or historical research purposes, or for statistical purposes, in accordance with Article 89, paragraph 1, based on Union law or the laws of the Member States, which must be proportional to the objective pursued, essentially respect the right to data protection, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject.

3. The personal data referred to in paragraph 1 may be processed for the purposes mentioned in paragraph 2, letter h), when their processing is carried out by a professional subject to the obligation of professional secrecy, or under their responsibility, in accordance with Union law or the laws of the Member States or with the rules established by the competent national authorities, or by any other

person also subject to the obligation of secrecy in accordance with Union law or the laws of the Member States or the rules established by the competent national authorities.

4. Member States may maintain or introduce additional conditions, including limitations, regarding the processing of genetic data, biometric data, or data concerning health."

It should be noted that special category data are those personal data whose processing requires enhanced protection due to their special impact on privacy, public freedoms, and the fundamental rights of the individual. Thus considered, their processing is, in principle, prohibited by the GDPR, unless one of the circumstances indicated in Article 9.2 of the GDPR exists.

Therefore, special category data are personal data that, due to their importance for the individual's privacy, must be processed with greater care and following special requirements.

Recital 71 states: "Regarding automated decisions and profiling, data controllers must use methods that correct 'the factors that introduce inaccuracies in personal data and minimize the risk of error, ensure personal data in such a way that possible risks to the interests and rights of the data subject are taken into account, and prevent, among other things, discriminatory effects on individuals based on race or ethnic origin, political opinions, religion or beliefs, trade union affiliation, genetic condition or health status or sexual orientation, or processing that leads to measures that produce such effects.'" (the underlining is from the AEPD).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

22/50

Article 4.15 of the GDPR defines "health data" as "personal data related to the physical or mental health of a natural person, including the provision of health care services, which reveal information about their health status."

Recital 35 of the GDPR clarifies this definition by stating that "Health-related personal data must include all data concerning the health status of the data subject that provides information about their past, present, or future physical or mental health. This includes information about the natural person collected in connection with their registration for health care purposes, or in connection with the provision of such care, in accordance with Directive 2011/24/EU of the European Parliament and of the Council; any number, symbol, or data assigned to a natural person that uniquely identifies them for health purposes; information obtained from tests or examinations of a part of the body or a bodily substance, including that derived from genetic data and biological samples, and any information relating, for example, to an illness, a disability, the risk of suffering from diseases, medical history, clinical treatment, or the physiological or biomedical status of the data subject, regardless of its source, for example, a doctor or other health professional, a hospital, a medical device, or an in vitro diagnostic test."

It is worth noting that the Court of Justice of the European Union (CJEU) has established a broad concept of health data. Thus, in accordance with the CJEU ruling of October 4, 2024, in case C 21/23 (the emphasis is from the AEPD):

"76 Among these special categories of personal data, which are listed in Article 8(1) of Directive 95/46 and in Article 9(1) of the GDPR, are health-related data. These include, in accordance with Article 4(15) of the Regulation, in relation to its Recital 35, all personal data that reveal information about the past, present, or future physical or mental health status of a natural person, including data related to the provision of health care services to that person.

81 In this regard, the Court of Justice has already stated that, in light of the objective of Directive 95/46 and the GDPR, to ensure a high level of protection of the freedoms and fundamental rights of natural persons, in particular, their privacy, in relation to the processing of personal data that affects them, the concept of "health-related data" provided for in Article 9(1) of that Regulation and in Article 8(1) of the aforementioned Directive must be interpreted broadly (see, in this regard, the judgments of November 6, 2003, *Lindqvist*, C 101/01, EU:C:2003:596, paragraph 50, and August 1, 2022, *Vyriausioji tarnybinės etikos komisija*, C 184/20, EU:C:2022:601, paragraph 125)."

Furthermore, the same CJEU ruling determines that when the processing of personal data may indirectly reveal sensitive information about a person, such data falls under the regime provided for in Article 9 of the GDPR:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

23/50

“82 In particular, such provisions cannot be interpreted to mean that the processing of personal data that may indirectly reveal sensitive information about a natural person is outside the enhanced protection regime established by the aforementioned provisions, as being excluded would undermine the useful effect of that regime and the protection of the freedoms and fundamental rights of natural persons that it aims to guarantee (judgment of August 1, 2022, Vyriausioji tarnybinės etikos komisija, C 184/20, EU:C:2022:601, paragraph 127)”.

In the same vein, the aforementioned judgment determines that special categories of personal data are subject to the prohibition of Article 9 of the GDPR regardless of whether the information is accurate or not and whether the processing aims to obtain personal data belonging to that category:

“87 This prohibition in principle is independent of whether the information revealed by the processing in question is accurate or not and of whether that pharmacist acts with the aim of obtaining information included in any of the special categories contemplated in Article 8, paragraph 1, of Directive 95/46 and Article 9, paragraph 1, of the GDPR. Indeed, taking into account the significant risks to the fundamental freedoms and rights of the data subjects generated by any processing of personal data included in such categories, these provisions aim to prohibit such processing, regardless of the purpose expressed and the accuracy of the information in question [see, in this regard, the judgment of July 4, 2023, Meta Platforms and others. (General terms of service of a social network), C 252/21, EU:C:2023:537, paragraphs 69 and 70]”.

For its part, the Supreme Court ruling of October 8, in the cassation appeal 1920/21, reaffirms the broad concept of health data, stating that:

“(…) it should be emphasized, in this regard, that the reading of Article 4.15 and Recital 35 of the General Data Protection Regulation supports, as the judgment of the contested National Court maintains, the inclusion of the notion of 'data related to health' of the data referring to the health status of athletes, since, although the European Union regulations do not contain any specific provision regarding data related to the application of doping control techniques, it broadly defines the processing of health data. Recital 35 of the aforementioned Regulation (EU) 2016/679 specifically includes, among the data related to health, all data related to the health status of the data subject that provides information about their physical or mental health status past, present, or future, including information about the natural person collected in connection with their registration for healthcare purposes, or in connection with the provision of such assistance, accordingly.”

There is no doubt, therefore, that data concerning the dispensing of medications or diapers by a pharmacy, the CIPA (Autonomous Personal Identification Code), and the health card number are health data, as well as

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

24/50

also includes all those that indirectly reveal a person's health status.

In any case, the circumstances that allow for the lifting of the prohibition on the processing of health data established by Article 9.1 are determined in Article 9.2 of the GDPR. That is to say, it is necessary for one of the premises established in the aforementioned article to be present in order for the processing of health data to be carried out. These exceptions must be interpreted restrictively, as can be inferred from recitals 51 to 56 of the GDPR.

The dispensing of medications and diapers involves the processing of health data, and the lifting of the

prohibition on processing this data will be found in Article 9.2 h); to the extent that the processing is necessary for the provision of health assistance or treatment.

Furthermore, Article 9.3 requires, for the specific premise of Article 9.2 h), that the processing be carried out by a professional subject to the obligation of professional secrecy or under their responsibility.

The lifting of the prohibition contained in letter h) of Article 9.2, as well as the additional provisions of Article 9.3 for the use of this premise, requires a rule of EU law or of the Member State that regulates it, which, in the case of Spain, requires that the health assistance or treatment be included in a norm with the rank of law, to the extent that the right to the protection of personal data is a fundamental right. In this regard, the different operations of personal data processing involved in the dispensing of medications by pharmacies would find their authorization in Law 14/1986, of April 25, General Health Law; Law 16/1997, of April 25, on the Regulation of Pharmacy Office Services; Royal Legislative Decree 1/2015, of July 24, which approves the consolidated text of the Law on Guarantees and the Rational Use of Medicines and Health Products; as well as in the applicable regional legislation, such as, in the case of Catalonia, Law 31/1991, of December 13, on Pharmaceutical Regulation of Catalonia.

Thus, for example, pharmacies are obliged, in accordance with Article 86.3 of Royal Legislative Decree 1/2015, of July 24, to "dispense medications that are requested both by individuals and by the National Health System."

IV

Unfulfilled Obligation. Article 6 of the GDPR. Lawfulness of Processing

Article 6 of the GDPR establishes the following:

"1. Processing shall be lawful only if at least one of the following conditions is met:

a) the data subject has given consent to the processing of their personal data for one or more specific purposes;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@pd.gob.es

25/50

b) the processing is necessary for the performance of a contract in which the data subject is a party or for the implementation at the request of the data subject of pre-contractual measures;

c) the processing is necessary for compliance with a legal obligation to which the data controller is subject;

d) the processing is necessary to protect vital interests of the data subject or of another natural person;

e) the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller;

f) the processing is necessary for the purposes of legitimate interests pursued by the data controller or by a third party, provided that such interests are not overridden by the interests or fundamental rights and freedoms of the data subject which require the protection of personal data, in particular when the data subject is a child.

The provision in point f) of the first paragraph shall not apply to processing carried out by public authorities in the exercise of their functions.

2. Member States may maintain or introduce more specific provisions in order to adapt the application of the rules of this Regulation regarding processing in compliance with paragraph 1, points c) and e), by setting more precise specific requirements for processing and other measures that ensure lawful and fair processing, including other specific situations of processing under Chapter IX.

3. The basis for the processing indicated in paragraph 1, points c) and e), shall be established by:

a) Union law, or

b) the law of the Member States applicable to the data controller.

The purpose of the processing shall be determined in that legal basis or, in relation to the processing referred to in paragraph 1, point e), shall be necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller. This legal basis may

contain specific provisions to adapt the application of the rules of this Regulation, including: the general conditions governing the lawfulness of processing by the controller; the types of data subject to processing; the affected data subjects; the entities to which personal data may be communicated and the purposes of such communication; the limitation of purpose; the retention periods for the data, as well as the operations and procedures of processing, including measures to ensure lawful and fair processing, such as those relating to other specific situations of processing under Chapter IX. Union law or the law of the Member States shall pursue a public interest objective and shall be proportionate to the legitimate aim pursued.

4. When processing for a purpose other than that for which the personal data were collected is not based on the consent of the data subject or on Union law or the law of the Member States that constitutes a necessary and proportionate measure in a democratic society to safeguard the objectives set out in Article 23, paragraph 1, the data controller, in order to determine whether the processing for another purpose is compatible with the purpose for which the personal data were initially collected, shall take into account, among other things:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@aepd.gob.es

26/50

- a) any relationship between the purposes for which the personal data was collected and the purposes of the further processing envisaged;
- b) the context in which the personal data was collected, in particular regarding the relationship between the data subjects and the data controller;
- c) the nature of the personal data, specifically when special categories of personal data are processed, in accordance with Article 9, or personal data relating to criminal convictions and offenses, in accordance with Article 10;
- d) the possible consequences for the data subjects of the further processing envisaged;
- e) the existence of appropriate safeguards, which may include encryption or pseudonymization."

In this regard, Recital 32 of the GDPR states that: "Consent must be given by a clear affirmative act that reflects the data subject's free, specific, informed, and unambiguous indication of their wishes to accept the processing of personal data concerning them, such as a written statement, including by electronic means, or a verbal statement. This could include ticking a box on an internet website, choosing technical parameters for the use of information society services, or any other statement or conduct that clearly indicates in this context that the data subject accepts the proposed processing of their personal data. Therefore, silence, pre-ticked boxes, or inactivity should not constitute consent. Consent must be given for all processing activities carried out for the same or similar purposes. When processing has multiple purposes, consent must be given for all of them. If the data subject's consent is to be given in response to a request by electronic means, the request must be clear, concise, and not unnecessarily disrupt the use of the service for which it is provided."

Furthermore, Article 4 of the GDPR, relating to definitions, establishes in paragraph 11:

"11) 'consent of the data subject': any freely given, specific, informed, and unambiguous indication of the data subject's wishes by which they, by a statement or by a clear affirmative action, signify their agreement to the processing of personal data concerning them;"

On the other hand, Article 24 of the GDPR develops the principle of proactive responsibility of the data controller, requiring that their actions not only comply with the GDPR but also be able to demonstrate such compliance:

"Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is performed in accordance with this Regulation. Such measures shall be reviewed and updated as necessary."

In summary, the processing of personal data requires the existence of a legal basis that legitimizes it. The choice of the most appropriate basis for processing, in the case of multiple bases existing, lies

with the controller, just as it is their responsibility to demonstrate that the processing is carried out in accordance with a legitimizing basis.

In accordance with Article 6.1 of the GDPR, in addition to consent, there are other possible bases that legitimize the processing of data without the need for consent.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeppd.gob.es

27/50

the authorization of its holder, in particular, when necessary for the execution of a contract in which the affected party is a party or for the application, at the request of this party, of pre-contractual measures, or when necessary for the satisfaction of legitimate interests pursued by the data controller or by a third party, provided that such interests do not prevail over the interests or the rights and fundamental freedoms of the affected party requiring the protection of such data. The processing is also considered lawful when necessary for compliance with a legal obligation applicable to the data controller, to protect vital interests of the affected party or another natural person, or for the performance of a task carried out in the public interest or in the exercise of public powers conferred on the data controller.

In this case, the reported party provided diapers to the residents of two geriatric centers from 2017 until at least February 14, 2024, the date on which an inspection was carried out at its establishment. To carry out this provision, it processed the personal data of the residents. This is stated in the Act (...) of the Pharmacy Inspection which notes: “(...)”.

This fact is confirmed by the reported party in its document dated November 20, 2024, in which it states: “(...)”.

The personal data of the residents was obtained through another pharmacy office, which varied over time: from 2017 until October 28, 2022, a pharmacy located at ***ADDRESS.4; from that date, pharmacy F.F.F.; and since February 13, 2023, pharmacy ***ADDRESS.3.

The manner of accessing the data of the residents was orchestrated through the access keys to the program ***PROGRAM.1 that were sent to them by the other pharmacy, without prejudice to the fact that the same pharmacy sent them unencrypted emails containing the data of the residents (including health data). This is recorded in the aforementioned act: “(...)”.

Therefore, from 2017 to the present, or at least until February 14, 2024, since the reported party has not confirmed this point, the reported party has provided diapers to approximately 60 residents of at least two different residences.

According to what was submitted by the reported party, the processing of the data would be covered by agreements for data transfer supposedly signed (the documents are unsigned) between pharmacy F.F.F. or pharmacy ***ADDRESS.3 and the reported party. In these, it is identified as the basis for legitimacy “articles 6.1 c) and 9.2 c) 3”.

However, neither the aforementioned basis for legitimacy nor that corresponding to the exercise of a public interest mission, recognized in a norm with the rank of law, are considered sufficient for the processing of data carried out. As previously noted, the regulatory provisions contained in the specific sectoral legislation would lift the prohibition on the processing of health data by pharmacies, in accordance with article 9.2 h), but it cannot be considered that the aforementioned regulatory provisions cover the processing of a specific pharmacy.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeppd.gob.es

28/50

to the detriment of another and that, therefore, may constitute a basis for legitimacy by themselves.

It is worth noting that the specific sectoral regulations enshrine the principle of freedom of choice of pharmacy for the user or patient, as determined in the Preliminary Questions of this document, which means that the patient or user is free to choose the pharmacy they wish to proceed with the dispensing of their medication.

That said, in the present case, there is no record of the patients' consent for the processing of their data by the respondent for the dispensing of diapers.

Furthermore, the aforementioned record included the following statement: "(...)".

On the other hand, reviewing the different possible bases for legitimacy, there is no evidence of a contract signed between the respondent and the affected residents, as holders of the fundamental right.

Regarding vital interest, Recital 46 of the GDPR establishes the exceptional nature of this legal basis and its uniqueness, stating that personal data should only be processed on this basis when the processing cannot be manifestly based on a different legal basis. It also mentions that certain types of processing may respond to both significant public interest reasons and the vital interests of the data subject, such as when processing is necessary for humanitarian purposes, including the control of epidemics and their spread, or in situations of humanitarian emergency, especially in cases of natural or man-made disasters.

The consideration of vital interest necessarily refers to the existence of a certain, plausible risk, not simply a potential one based on general, non-specific data, in light of the necessity of this specific processing that overrides other legal bases for processing, such as consent.

Finally, the legitimate interest of the respondent would require the existence of this interest in the first place, and subsequently, a balancing of it with the rights and freedoms of the affected individuals, something that is not evident in the present case.

In summary, there is no evidence of a legal basis that supports the dispensing of diapers carried out by the respondent concerning the personal data of the residents of the aforementioned geriatric centers. Therefore, in accordance with the evidence available at this moment in the initiation of the sanctioning procedure, it is considered that the known facts could constitute an infringement attributable to the respondent for violation of Article 6 of the GDPR.

V

Classification of the infringement of Article 6.1 of the GDPR and qualification for the purposes of prescription.

Article 83.5 of the GDPR classifies as an administrative infringement the violation of the following article, which will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the sole purpose of the prescription period, Article 72.1 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and will prescribe after three years, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679."

VI

Proposal for a sanction for non-compliance with Article 6 of the GDPR.

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected individuals and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the affected individuals;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented under Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

30/50

- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor reported the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58(2) have previously been ordered against the controller or processor in relation to the same matter, compliance with those measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42; and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD states:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the graduated criteria established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The link between the infringer's activity and the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.”

In the present case, considering the severity of the possible infringement, particularly taking into account the consequences that its commission causes to the affected parties, the imposition of a fine would be appropriate, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the

C/ Jorge Juan, 6

www.aepd.es

instruction, it is considered appropriate to adjust the sanction to be imposed according to the following circumstances, as contemplated in the aforementioned provisions.

-
The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damages and losses they have suffered (Article 83.2(a) of the GDPR): the alleged facts negatively impact the control of the affected individuals over their personal data, with control over personal data being a fundamental element and the backbone of the GDPR. Ultimately, the actions carried out by the reported party imply the loss of control and disposition of the data concerning the holder of the fundamental right. In this regard, the number of affected individuals cannot be overlooked (at least 60 people) and the duration of the infringement (from 2017 to the present, as it has not been proven otherwise) and that the infringement was carried out following a structured manner, regardless of the pharmacy from which the data was obtained over the years, which makes the infringement acquire “systemic” connotations.

Lastly, it is noted that the lack of evidence of the existence of a legal basis for carrying out the processing constitutes a violation of the principle of proactive responsibility provided for in Article 5.2 of the GDPR, an essential principle of data protection regulation.

-
The intent or negligence in the infringement (Article 83.2(b)): serious negligence is observed to the extent that the processing of health data is carried out in violation of specific sectoral regulations, based on the free choice of pharmacy by patients, as well as the Code of Ethics of the pharmaceutical profession approved by the General Council of Pharmaceutical Colleges, which establishes that “any action in the field of health that is directed at a patient or user requires the informed, free, and voluntary consent of the latter. The pharmacist must respect their decision, in the terms established by law.”

-
The categories of personal data affected by the infringements (Article 83.2(g) of the GDPR): the Guidelines 04/2022 of the European Data Protection Committee, on the calculation of fines under the GDPR, adopted on May 24, 2023, in their section 57, state the following regarding the requirement to take into account the categories of affected personal data: “(...) the GDPR clearly highlights the types of data that deserve special protection and, therefore, a stricter response regarding fines. This refers, at a minimum, to the types of data referred to in Articles 9 and 10 of the GDPR and to data outside the scope of these articles whose dissemination causes immediate harm and detriment to the affected individual (for example, location data, data on private communication, national identification numbers, or financial data, such as transaction summaries or credit card numbers).” In the present case, the personal data subject to processing.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeapd.gob.es
32/50

include health data, such as, for example, the medical regimen of the affected individuals or the health card or CIPA number.

Furthermore, the following aggravating factors are considered in terms of severity:

- The connection of the infringer's activity with the processing of personal data (Article 83.2 k) of the GDPR in connection with Article 76.2, letter b), of the LOPDGDD): the party reported, as a consequence of its activity as a private healthcare establishment of public interest, regularly and continuously processes personal data of a large number of data subjects (all its patients or users) essential for the development of its business. The provision of medical and pharmaceutical products, which is its main activity, necessarily involves operations of personal data processing. Thus, the

infringing actions occur within the framework of personal data processing that the reported party routinely conducts in its business and linked to it.

- The benefits obtained as a result of the commission of the infringement (Article 83.2 k) of the GDPR in connection with Article 76.2, letter c) of the LOPDGDD): the dispensing of pharmaceutical products to patients from different residences without a legal basis implies that the reported pharmacy has provided a service (provision of diapers) in exchange for economic compensation. In short, the pharmacy has profited from the actions that constitute the infringement.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 6.1 of the GDPR, allows for the initial determination, and without prejudice to the outcome of the investigation of this sanctioning procedure, an administrative fine of €5,000.

VII

Unfulfilled obligation. Article 14 GDPR. Information to be provided when personal data has not been obtained from the data subject

According to the provisions of Article 14 of the GDPR:

"1. When personal data has not been obtained from the data subject, the data controller shall provide the following information:

- a) the identity and contact details of the controller and, where applicable, of its representative;
- b) the contact details of the data protection officer, where applicable;
- c) the purposes of the processing for which the personal data are intended, as well as the legal basis for the processing;
- d) the categories of personal data concerned;
- e) the recipients or categories of recipients of the personal data, where applicable;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@epd.gob.es

33/50

f) where applicable, the intention of the data controller to transfer personal data to a recipient in a third country or international organization and the existence or absence of an adequacy decision by the Commission, or, in the case of transfers referred to in Articles 46 or 47 or Article 49, paragraph 1, second sentence, reference to the appropriate or suitable safeguards and the means to obtain a copy of them or the location where they are made available.

2. In addition to the information mentioned in paragraph 1, the data controller shall provide the data subject with the following information necessary to ensure fair and transparent data processing regarding the data subject:

- a) the period for which the personal data will be retained or, when that is not possible, the criteria used to determine that period;
- b) when the processing is based on Article 6, paragraph 1, letter f), the legitimate interests of the data controller or a third party;
- c) the existence of the right to request from the data controller access to personal data concerning the data subject, and its rectification or erasure, or the restriction of its processing, and to object to the processing, as well as the right to data portability;
- d) when the processing is based on Article 6, paragraph 1, letter a), or Article 9, paragraph 2, letter a), the existence of the right to withdraw consent at any time, without affecting the lawfulness of the processing based on consent before its withdrawal;
- e) the right to lodge a complaint with a supervisory authority;
- f) the source from which the personal data originate and, where applicable, whether they come from publicly accessible sources;
- g) the existence of automated decision-making, including profiling, referred to in Article 22, paragraphs 1 and 4, and, at least in such cases, significant information about the logic involved, as well as the significance and the expected consequences of such processing for the data subject.

3. The data controller shall provide the information indicated in paragraphs 1 and 2:

- a) within a reasonable period, once the personal data have been obtained, and at the latest within one month, taking into account the specific circumstances in which the data are processed;
- b) if the personal data are to be used for communication with the data subject, at the latest at the time of the first communication to that data subject, or
- c) if it is intended to communicate them to another recipient, at the latest at the time when the personal data are first communicated.

4. When the data controller intends to further process the personal data for a purpose other than that for which they were obtained, it shall provide the data subject, prior to such further processing, information about that other purpose and any other pertinent information indicated in paragraph 2.

5. The provisions of paragraphs 1 to 4 shall not apply when and to the extent that:

- a) the data subject already has the information;
- b) the communication of such information proves impossible or would involve a disproportionate effort, in particular for processing for archiving purposes in the public interest.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@epd.gob.es

34/50

public, for scientific or historical research purposes or for statistical purposes, subject to the conditions and guarantees indicated in Article 89, paragraph 1, or to the extent that the obligation mentioned in paragraph 1 of this article may severely hinder or obstruct the achievement of the objectives of such processing. In such cases, the controller shall take appropriate measures to protect the rights, freedoms, and legitimate interests of the data subject, including making the information public;

c) the obtaining or communication is expressly provided for by Union or Member State law applicable to the data controller and which establishes appropriate measures to protect the legitimate interests of the data subject, or

d) when the personal data must continue to be confidential based on a professional secrecy obligation regulated by Union or Member State law, including a legal obligation of secrecy."

When personal data relating to a person is obtained, and it has not been obtained directly from that person, the data controller must provide them with all the information regarding the processing of their data as indicated in Article 14 of the GDPR. The GDPR requires that this information be provided as soon as possible and, in any case, no later than one month, or in the event that a communication must be made, no later than at the time of that first communication or at the time when it is to be communicated to another recipient, at the latest. In this regard, Recital 61 states:

61) "Data subjects should be provided with information on the processing of their personal data at the time when it is obtained from them or, if obtained from another source, within a reasonable period, depending on the circumstances of the case. If the personal data can be legitimately communicated to another recipient, the data subject should be informed at the time when it is communicated to the recipient for the first time. The data controller intending to process the data for a purpose other than that for which it was collected must provide the data subject, prior to such further processing, information about that other purpose and any other necessary information. When the source of the personal data cannot be provided to the data subject because multiple sources have been used, general information must be provided."

It is important to emphasize that the obligation to inform in Article 14 of the GDPR must be understood within the framework of the rights of data subjects in relation to transparency, a principle that must govern the processing of data in accordance with Article 5.1 a) of the GDPR. In this sense, Article 12.1 of the GDPR states:

"(...) The data controller shall take appropriate measures to provide the data subject with all the information referred to in Articles 13 and 14 (...) in a concise, transparent, intelligible, and easily accessible form, using clear and plain language (...)."

In this regard, it is essential to refer to Recital 39 of the GDPR which establishes that:

"(39) All processing of personal data must be lawful and fair. For natural persons, it must be completely clear that data is being collected,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeapd.gob.es
35/50

using, consulting, or otherwise processing personal data concerning them, as well as the extent to which such data is or will be processed. The principle of transparency requires that all information and communication regarding the processing of such data be easily accessible and easy to understand, and that simple and clear language be used. This principle particularly refers to the information provided to data subjects about the identity of the data controller and the purposes of the processing, as well as the additional information necessary to ensure fair and transparent processing concerning the affected individuals and their right to obtain confirmation and communication of the personal data concerning them that is being processed. Individuals must be aware of the risks, rules, safeguards, and rights related to the processing of personal data, as well as how to assert their rights in relation to the processing. In particular, the specific purposes of the processing of personal data must be explicit and legitimate, and must be determined at the time of collection. Personal data must be adequate, relevant, and limited to what is necessary for the purposes for which they are processed. This requires, in particular, ensuring that the retention period is strictly limited to a minimum. Personal data should only be processed if the purpose of the processing cannot be reasonably achieved by other means. To ensure that personal data is not kept longer than necessary, the data controller must establish deadlines for its deletion or periodic review. All reasonable measures must be taken to ensure that inaccurate personal data is rectified or deleted. Personal data must be processed in a manner that ensures adequate security and confidentiality of the personal data, including to prevent unauthorized access or use of such data and the equipment used in the processing.

In addition to what is established in Recital 60, which states:

60) “(...) The principles of fair and transparent processing require that the data subject be informed of the existence of the processing operation and its purposes. The data controller must provide the data subject with any additional information necessary to ensure fair and transparent processing, taking into account the specific circumstances and context in which the personal data are processed (...).”

In the present case, the personal data of the residents was provided to (...) by means of another pharmacy, which changed over the years: from 2017 until October 28, 2022, a pharmacy at ***ADDRESS.4; from that date, the pharmacy ***F.F.F.; and since February 13, 2023, the pharmacy ***ADDRESS.3.

As noted, the way to access the data of the residents was orchestrated through the access keys to the program ***PROGRAM.1 that were sent to them by the other pharmacy, without prejudice to the fact that the same pharmacy sent them unencrypted emails containing the data of the residents (including health data).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeapd.gob.es
36/50

There is no documentation that proves that the accused party provided the affected individuals, whose personal data was processed for the purpose of dispensing diapers, with any information regarding any of the elements contained in Article 14 of the GDPR.

In fact, the accused party has omitted any mention of this fact in its response to this Agency during the information request made in the preliminary investigation proceedings. However, the information provided by the Pharmacy Inspection states that: “(...)”.

Therefore, in accordance with the evidence available at this time in the agreement to initiate sanctioning proceedings, it is considered that the known facts could constitute an infringement, attributable to the accused party for violation of Article 14 of the GDPR transcribed above.

Qualification of the infringement of Article 14 of the GDPR and qualification for the purposes of prescription

Article 83.5 of the GDPR classifies the violation of the following article as an administrative infringement, which will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

"b) the rights of the data subjects pursuant to Articles 12 to 22;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the sole purpose of the prescription period, Article 72.1 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and will prescribe after three years, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

h) The omission of the duty to inform the affected party about the processing of their personal data in accordance with the provisions of Articles 13 and 14 of Regulation (EU) 2016/679 and 12 of this organic law."

IX

Proposal for sanction for non-compliance with Article 14 of the GDPR.

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR and 76 of the LOPDGDD must be observed, provisions reproduced above.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@aepd.gob.es

37/50

In this case, considering the seriousness of the possible infringement, particularly the consequences that its commission causes to those affected, the imposition of a fine would be appropriate, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and deterrent, in accordance with the provisions of Article 83.1 of the GDPR.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to scale the sanction to be imposed according to the following circumstances, as contemplated in the aforementioned provisions:

- The seriousness of the infringement (Article 83.2(a) of the GDPR): it is emphasized that in this case no type of information has been provided to the residents (not even the most basic, such as who and for what purpose the data is used), when the information provided to the data subject by a controller is essential for them to be aware of the existence of processing and its purposes, among other aspects, allowing for genuine control over their data, including the possibility for the data subject not to provide it. In this regard, it is necessary to highlight the duration of the infringement, which is unknown if it continues today, notwithstanding that it began in 2017, as acknowledged by the reported party.

- The intent or negligence in the infringement (Article 83.2(b)): there is serious negligence in that the lack of information occurs in violation of the Code of Ethics of the pharmaceutical profession approved by the General Council of Pharmaceutical Colleges, which establishes that "the pharmacist must provide information to the patient/user in an objective, updated, simple, and appropriate manner to the understanding capabilities of the person being attended to, and must do so in writing if requested."

Furthermore, it is determined that "patients and users have the right to know the identity and qualifications of the professional attending to them."

- The categories of personal data affected by the infringements (Article 83.2(g) of the GDPR): the Guidelines 04/2022 of the European Data Protection Board, regarding the calculation of fines under the GDPR, adopted on May 24, 2023, in their section 57, state the following regarding the requirement

to take into account the categories of personal data affected: "(...) the GDPR clearly highlights the types of data that deserve special protection and, therefore, a stricter response regarding fines. This refers, at a minimum, to the types of data referred to in Articles 9 and 10 of the GDPR and to data outside the scope of these articles whose dissemination causes immediate harm to the data subject (for example, location data, data on private communication, national identification numbers, or financial data, such as transaction summaries or credit card numbers).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sede.aepd.gob.es
38/50

credit"). In the present case, the personal data subject to processing includes health data, such as, for example, the medical regimen of the affected individuals or the number of the health card or CIPA.

Furthermore, the following aggravating factors are considered:

- The connection of the infringer's activity with the processing of personal data (Article 83.2 k) of the GDPR in connection with Article 76.2, letter b), of the LOPDGDD): the pharmacy, as a result of its activity as a private healthcare establishment of public interest, regularly and continuously processes personal data of a large number of individuals (all its patients or users), which is essential for the development of its business. The performance of activities related to the dispensing of medical and pharmaceutical products, which is its main activity, necessarily involves operations of personal data processing. Thus, the infringing actions occur within the framework of personal data processing that the pharmacy routinely conducts in its business and related to it.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 14 of the GDPR, allows for the initial setting of an administrative fine of €3,000.00 (THREE THOUSAND EUROS).

X

Unfulfilled obligation. Article 32 of the GDPR. Security of processing.

Article 32 of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sede.aepd.gob.es
39/50

3. Adherence to a code of conduct approved pursuant to Article 40 or to a certification mechanism

approved pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements established in paragraph 1 of this Article.

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the data controller or the data processor and having access to personal data may only process such data following the instructions of the data controller, unless required to do so by Union law or the laws of the Member States.

The obligation to adopt all technical and organizational measures imposed by Article 32 of the GDPR on the data controller is a manifestation of the two essential pillars of the GDPR: proactive accountability enshrined in Article 5.2 and developed in Article 24.1 of the GDPR, and the risk-based approach. Thus, Article 32, while establishing a set of measures that could be considered minimal to be adopted by the data controller, such as pseudonymization or data encryption, cannot in any case be understood as a *numerus clausus* since these must address the nature, scope, context, and purposes of the processing, as well as the likelihood and severity of risks affecting personal data. As can be observed, there has been a shift from a reactive system to a proactive one, based on prevention rather than correction, which must operate throughout the entire lifecycle of personal data, not only at the point of collection. In this regard, Recital 74 of the GDPR states (the emphasis is from the AEPD):

“74 The responsibility of the data controller for any processing of personal data carried out by them or on their behalf must be established. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons.”

For its part, Recital 75 determines:

“(75) Risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing could lead to discrimination issues, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where individuals are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health, or data concerning sexual life, or criminal convictions and related security measures; in cases where...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@epd.gob.es

40/50

cases in which personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, is processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects.”

In the present case, the pharmacy, as a private healthcare establishment with public interest, predominantly carries out processing of particularly sensitive data, such as health data. This circumstance must be taken into account when establishing appropriate security measures relative to the risk.

The risk-based approach to data protection entails adopting and implementing measures aimed at protecting the confidentiality, availability, and integrity of personal data, where the risk to rights and freedoms acts as a switch or modulator for the measures to be adopted.

In this regard, the CJEU ruling of December 14, 2023, *Natsionalna agentsia za prihodite*, case

C-340/21, EU:C:2023:986 states:

"[the adoption of security measures in relation to personal data protection] is not fulfilled by the adoption of any measure, as they must be necessary to ensure those objectives set by the provision, and of course, it is not enough to formally approve the security measures, as it is required that they be established and effectively implemented in practice. We have consequently considered that there is an obligation of result, consisting of adopting the necessary measures to prevent data from being lost, misplaced, or ending up in the hands of third parties. Ultimately, every data controller (or processor) is, by legal provision, a debtor of security in relation to data, and must ensure that such measures or mechanisms are effectively implemented in practice."

In the present case, there are elements that would indicate that the reported party lacked the appropriate technical and organizational measures relative to the level of risk to guarantee the protection of the personal data of the residents processed, especially their confidentiality.

It is the pharmacy itself that describes the manner of acting, as recorded in the minutes (...) of the Pharmacy Inspection of Catalonia and in the document sent by the latter to this Agency:

"The pharmacy ***F.F.F. sends you an Excel file with the names and surnames of the patients and the diapers to be dispensed via an unencrypted email. That the pharmacy had provided them access (username and password) to the software program ***PROGRAM.1 with which they obtain the name, CIP, and active prescription number of the residents in order to dispense the diapers (with the change of residence, they also changed the password). Before the 25th of each month, they send an email."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

41/50

electronic file to the pharmacy ***F.F.F., which contains the names of the residents, type of diaper, date of dispensing, and specific monetary contribution of each resident. Also, monthly, they send an email to Mr. E.E.E. of ***EMPRESA.2: ***EMAIL.2 with the general invoice for the dispensing of diapers and, along with the last delivery of the month of coupon seals, the carrier from ***EMPRESA.2 delivers an envelope with cash containing the total amount of the contributions."

That is to say, from the account ***EMAIL.1 and unencrypted, personal data of the patients requiring diapers was sent to the accused, in Excel sheets, including health data, and subsequently, the accused party sent an email to the aforementioned account, with the list of monetary contributions from the residents, which were later reimbursed from the other pharmacy. This manner of acting was maintained, starting from March 13, 2024, when the pharmacy ***DIRECCIÓN.3 began to provide the information, as evidenced by the email received by the accused party that same day from the address ***EMAIL.3: "(...)".

Furthermore, in the Treatment Activity Record (RAT) document, and more specifically in its section "There is a data encryption system," it states:

"Since they do not transmit data considered to be of high level, they do not have a data encryption system. However, it is recommended that this measure be adopted whenever personal data is transmitted or transferred, regardless of the level of security of the same.

Regarding the security of email, the "Best Practices Report" of May 2021, CNN-CERT BP02, from the National Cryptologic Center, a service attached to the National Intelligence Center, whose mission is to contribute to the improvement of Spanish cybersecurity, includes a series of vulnerabilities of email and the various ways in which they can be attacked, as well as security recommendations. In section 4.2 of this Report, the "Security of communications via email" is described, with the following assertions on pages 37 to 39:

"The protocol involved in this sending process is SMTP. This protocol has been used since 1982, and when it was implemented, security measures such as encryption or authentication of communications were not taken into account. This means that the entire sending process described above would be carried out in plain text, that is, at any point in the transmission, an attacker could see and manipulate the content of the emails. Due to these shortcomings in SMTP, various technologies and extensions have been developed that allow for the incorporation of security measures to guarantee authentication,

integrity, and encryption of email communications. Some of the most well-known technologies are STARTTLS, SPF, DKIM, and DMARC... Although the most well-known email providers such as Google, Yahoo, and Outlook encrypt and authenticate emails using these types of technologies, many organizations continue to use email carelessly. It should also be noted that these technologies must be implemented both at the source and at the destination for them to be utilized. Furthermore, some of these measures are susceptible to being attacked. For example, STARTTLS is vulnerable to downgrade attacks, where an attacker in a man-in-the-middle situation can force the TLS negotiation not to take place (it would be enough to replace the STARTTLS chain).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sede.aepd.gob.es
42/50

Even in the event that TLS communication is successfully established, the email servers through which the email passes until it reaches its destination would have access to its content. Due to these facts, it is inferred that it is not sufficient to delegate the security of email to the underlying technologies responsible for delivering it to its recipient.”

This highlights that the defendant lacked a secure system for sending and receiving personal data of patients in residences. Thus, the communication channel established for the exchange of information and personal data between pharmacies suffers, at least until February 14, 2024, from a lack of security measures appropriate to the risk. Furthermore, as the defendant has not confirmed whether the processing of personal data has ceased or continues, it is presumed that the lack of measures persists to this day.

Therefore, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, it is considered that the known facts could constitute an infringement, attributable to the defendant for violation of Article 32 of the GDPR transcribed above.

XI

Classification of the infringement of Article 32 of the GDPR and qualification for the purposes of limitation

If confirmed, the aforementioned infringement of Article 32 of the GDPR could imply the commission of the infringements classified in Article 83.4 of the GDPR, which states:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71, establishes that: “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Serious Infringements” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a limitation period of two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.”

XII

Proposal for a sanction for non-compliance with Article 32 of the GDPR.

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR and Article 76 of the LOPDGDD, previously cited, must be observed.

In the present case, considering the seriousness of the possible infringement, particularly regarding the consequences that its commission causes to the affected parties, the imposition of a fine, in addition to the adoption of measures, if appropriate, would be warranted.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR.

For the purposes of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to scale the sanction to be imposed according to the following circumstances, contemplated in the aforementioned provisions.

- The categories of personal data affected by the infringements (Article 83.2, letter g), of the GDPR): the Guidelines 04/2022 of the European Data Protection Committee, on the calculation of fines under the GDPR, adopted on May 24, 2023, in its paragraph 57, state the following regarding the requirement to take into account the categories of personal data affected: "(...) the GDPR clearly highlights the types of data that deserve special protection and, therefore, a stricter response regarding fines. This refers, at a minimum, to the types of data referred to in Articles 9 and 10 of the GDPR and to data outside the scope of these articles whose dissemination causes immediate harm to the data subject (for example, location data, data on private communication, national identification numbers, or financial data, such as transaction summaries or credit card numbers)." In the present case, the personal data subject to processing includes health data, such as, for example, the medical regimen of the affected individuals or the number of the health card or CIPA, without prejudice to the fact that the CJEU has established a broad concept of health data.

Furthermore, the following aggravating factors are also considered:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeaeprd.gob.es
44/50

-

The connection of the infringer's activity with the processing of personal data (Article 83.2 k) of the GDPR in connection with Article 76.2, letter b), of the LOPDGDD): the accused, as a result of its activity as a private healthcare establishment of public interest, regularly and continuously processes personal data of a large number of data subjects (all its patients or users) that is essential for the development of its business. The performance of activities related to the dispensing of medical and pharmaceutical products, which is its main activity, necessarily involves operations of personal data processing. Thus, the infringing actions occur within the framework of a personal data processing that the pharmacy routinely carries out in its business and related to it. In accordance with the transcribed provisions, and without prejudice to what results from the instruction of the procedure, the initial assessment of the amount of the fine is €3,000.00 (THREE THOUSAND EUROS), for violation of Article 32 of the GDPR.

XIII

Corrective Measures

If the infringement is confirmed, the resolution issued may establish the corrective measures that the infringing entity must adopt to put an end to the non-compliance with personal data protection legislation, in this case regarding Articles 6, 14, and 32 of the GDPR, in accordance with the provisions of the aforementioned Article 58.2.d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations are in compliance with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame..."

Thus, the responsible entity may be required to align its actions with personal data protection regulations, to the extent expressed in the previous Legal Grounds.

In this act, the alleged infringement committed and the facts that could lead to this possible violation of data protection regulations are established, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to

comply with the GDPR and the LOPDGDD.

However, in this case, irrespective of the above, in accordance with the evidence available at this moment regarding the initiation of the sanctioning procedure, the resolution adopted may require the accused to adopt the following measures within a period of 3 months from the date of effectiveness of the resolution concluding this procedure:

- Certify the cessation of the processing of personal data for the dispensing of diapers to residents of geriatric centers, as well as the deletion of the mentioned personal data, unless it certifies the existence of a legal basis for this.
- Certify, in case of having a legal basis that supports the processing of their personal data, the provision of the information contained in Article 14 of the GDPR to the residents of the geriatric centers.
- Certify the adoption of measures appropriate to the risk in the terms provided by Article 32 of the GDPR.

The imposition of these measures is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

It is warned that failure to comply with the possible order to adopt measures imposed by this agency in the resolution of the present sanctioning procedure may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may motivate such conduct to initiate a further administrative sanctioning procedure.

It is also reminded that neither the acknowledgment of the infringement committed nor, where applicable, the voluntary payment of the proposed amounts, exempts from the obligation to adopt the pertinent measures to cease the conduct or correct the effects of the infringement committed and to certify compliance with this obligation before this AEPD.

Therefore, in light of the above, by the Presidency of the Spanish Agency for Data Protection, IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against A.A.A., with NIF: ***NIF.1 for:

- An alleged infringement of Article 6 of the GDPR classified in Article 83.5.a) of the GDPR.
- An alleged infringement of Article 14 of the GDPR, classified in Article 83.5.h) of the GDPR.
- An alleged infringement of Article 32 of the GDPR, classified in Article 83.4.a) of the GDPR.

SECOND: TO APPOINT L.L.L. as the instructor and M.M.M. as the secretary, indicating that they may be recused, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the file, for evidentiary purposes, the documents obtained and generated by the General Subdirectorate of Data Inspection in the actions prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be an administrative fine of:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@aepd.gob.es

46/50

- For the alleged violation of Article 6 of the GDPR, an administrative fine of 5,000 euros.
- For the alleged violation of Article 14 of the GDPR, an administrative fine of 3,000 euros.
- For the alleged violation of Article 32 of the GDPR, an administrative fine of 3,000 euros.

This amounts to a total of 11,000 euros, without prejudice to what may be determined during the investigation.

FIFTH: NOTIFY this agreement to A.A.A., with NIF: ***NIF.1, granting a hearing period of ten working days for them to submit allegations and present any evidence they deem appropriate. In their written allegations, they must provide their NIF and the procedure number that appears in the heading of this document.

In accordance with the provisions of Article 85 of the LPACAP, they may acknowledge their responsibility within the period granted for submitting allegations to this initiation agreement; this will entail a 20% reduction of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at 8,800 euros, resolving the procedure with the imposition of this sanction.

Similarly, they may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will imply a 20% reduction of its amount. With the application of this reduction, the sanction would be set at 8,800 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted for submitting allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions were to apply, the amount of the sanction would be set at 6,600 euros.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative route against the sanction.

In the event that they choose to proceed with the voluntary payment of any of the amounts indicated above (8,800 euros or 6,600 euros), they must do so by depositing it into account No. IBAN:

ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which they are entitled.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@aepd.gob.es

47/50

Likewise, they must send the proof of payment to the General Subdirectorate of Inspection along with the express communication of the withdrawal or renunciation of any action or appeal in the administrative route against the sanction to continue with the procedure in accordance with the amount deposited.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

1479-260325

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

>>

SECOND: On April 22, 2025, A.A.A. proceeded to pay the sanction in the amount of 6,600.00 euros, making use of the two reductions provided for in the previously transcribed initiation agreement, which implies the acknowledgment of responsibility regarding the facts referred to in the initiation agreement and its legal qualification.

THIRD: The initiation agreement transcribed above indicated that, if the violation were confirmed, measures could be imposed on the responsible party to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame...”.

Having acknowledged the responsibility for the violation, the imposition of the measures included in the initiation agreement is appropriate.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), it is competent to

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@epd.gob.es

48/50

to resolve this procedure, the Presidency of the Spanish Agency for Data Protection.

Likewise, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

- "1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.
2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another non-pecuniary sanction but the latter has been justified as inappropriate, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except with regard to the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.
3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of the initiation of the procedure, and their effectiveness shall be conditioned on the withdrawal or renunciation of any action or appeal in the administrative route against the sanction. The percentage of reduction provided in this section may be increased by regulation."

III

Voluntary payment and acknowledgment of responsibility

In accordance with the provisions of the aforementioned Article 85 of the LPACAP, the notified initiation agreement informed about the possibility of acknowledging responsibility and making voluntary payment of the proposed sanction, which would entail two cumulative reductions of 20% each. With the application of these two reductions, the sanction would be set at €6,600.00, and its payment would imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

After the notification of the aforementioned initiation agreement, A.A.A. has proceeded to acknowledge responsibility and make voluntary payment of the sanction, availing themselves of the two reductions provided. In accordance with section 3 of Article 85 LPACAP, the effectiveness of the aforementioned reductions will be conditioned on the withdrawal or renunciation of any action or appeal in the administrative route against the sanction.

It should be noted that, according to the provisions of the LPACAP, as well as the jurisprudence of the Supreme Court in this matter, the exercise of voluntary payment by the presumed responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their initiation form. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all issues raised by the interested parties and any others arising from it.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions, the Presidency of the Spanish Agency for Data Protection RESOLVES: FIRST: TO DECLARE the commission of the infringements and TO CONFIRM the sanctions determined in the dispositive part of the initiation agreement transcribed in this resolution. The sum of the aforementioned amounts yields a total of €11,000.00.

After A.A.A. has proceeded with the prompt payment and acknowledgment of responsibility, a reduction of 40% of the total mentioned is applied, which results in a definitive amount of €6,600.00. The effectiveness of the aforementioned reductions is conditioned, in any case, on the withdrawal or renunciation of any action or appeal in the administrative route.

SECOND: TO DECLARE the termination of procedure EXP202414366, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: TO ORDER A.A.A. to notify the Agency of the adoption of the measures described in the legal grounds of the initiation agreement transcribed in this resolution within 3 months from the date this resolution becomes final and enforceable.

FOURTH: TO NOTIFY this resolution to A.A.A.

FIFTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment and acknowledgment of responsibility on the withdrawal or renunciation of any action or appeal in the administrative route, this resolution will be final in the administrative route and fully enforceable from its notification.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative route as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file an appeal.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeaeppd.gob.es
50/50

Administrative contentious proceedings before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

However, in accordance with the provisions of Article 90.3.a) of the LPACAP, the firm resolution in the administrative route may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeaeppd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

1259-260325
Lorenzo Cotino Hueso
President of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeaeppd.gob.es